LumiEther Research leave app: handover

LumiEther Research leave app: handover

Written 2026-11-10 from the repo at commit `8798565` on branch `rebuild/react-helidon`. Every claim below comes from the code, the tests, the git history or the docs in this repo. Where nothing proves a thing, this file says so.

No secrets are in this file. Placeholders such as `<ADMIN_EMAIL>` and `<DATABASE_URL>` stand for values kept in `deploy/.env` on the machine that runs the app. That file is never committed.

1. What this is

An internal leave and payslip tool for about 5 people (`CLAUDE.md`). An admin manages employees, leave, comp-off, the leave policy and payslips. An employee sees only their own leave, comp-off, permissions, holidays and published payslips. Employees are never shown their yearly allowance or days left.

This branch is a rebuild of an existing Next.js app. The new parts:

Part	Where	Technology
Frontend	`frontend/`	React 19, Vite, TypeScript, Tailwind v4, shadcn parts on Base UI
Backend	`backend/`	Helidon SE 4 on Java 21, Maven, plain JDBC with HikariCP (pool of 5)
Database	`db/migrations/001` to `004`	PostgreSQL. Same schema and migrations as the old app.
PDF service	`pdf-service/`	WeasyPrint in Python. Unchanged from the old app.
Deploy	`deploy/`	Docker, one compose file, nginx in front

The old Next.js app is still in the repo root (`src/`) and in `~/lumiether-website`. It is the reference for behaviour. Do not edit either copy.

2. Status

Checked on 2026-11-10 by running the suites: backend `mvn test` ran 348 tests, 0 failed, 0 skipped. Frontend `vitest run` ran 173 tests in 9 files, all passed. `tsc --noEmit` and `eslint .` are clean. The database tests need a throwaway Postgres (`DATABASE_URL_TEST`); without one they are skipped.

"Tests" means automated tests in `backend/src/test` and `frontend/src`. The frontend tests run against a fake backend, so no frontend test talks to the real server. The backend `ApiTest` suite does test the HTTP layer against a real database.

Screen or feature	Code	Tests
Sign in, sign out, session cookie	`auth/`, `Api.java`	`PasswordTest`, `TokenTest`, `SessionsCookieTest`, `StoreAuthTest`, `ApiTest`; `auth.test.tsx`
Cross-site request guard	`web/CsrfGuard.java`	`CsrfGuardTest`, `ApiTest`
Change own password	`auth/ChangePassword.java`	`ApiTest`; `screens.test.tsx`
Admins: add, remove, last-admin rule	`Auth.java`, trigger in `001_init.sql`	`StoreAuthTest`, `ApiTest`; `screens.test.tsx`
Employees: add, category, payroll, remove	`Employees.java`, `Store.java`	`EmployeesTest`, `StoreEmployeesTest`, `ApiTest`; `employees.test.tsx`
Leave rules (balance, comp-off, expiry)	`domain/Leave.java`	`LeaveEngineTest` (56), `DatesTest`, `StoreLeaveTest`
Employee: apply, withdraw, cancel leave	`Requests.java`, `LeaveStore.java`	`RequestsTest`, `StoreLeaveTest`, `ApiTest`; `leave-screens.test.tsx`
Employee: comp-off claim	same	same
Employee: permissions	same	same
Admin: approve or reject leave, comp-off, cancellations	`LeaveStore.resolveRequest`	`StoreLeaveTest`, `ApiTest`; `leave-screens.test.tsx`
Admin pages "Leave requests" and "Comp-off"	`requests.tsx`	`leave-screens.test.tsx`
Admin and employee dashboards	`Api.java`, `*-dashboard.tsx`	`ApiTest`; `leave-screens.test.tsx`
Leave policy (days per category)	`LeaveStore`, `Api.java:594`	`StoreLeaveTest`, `ApiTest`; `leave-screens.test.tsx`

Screen or feature	Code	Tests
Holidays (read only)	`Api.java`	`ApiTest`; `leave-screens.test.tsx`
Payslips: generate, replace, publish, list	`payslip/`	`PayslipMoneyTest`, `PayslipTemplateTest`, `PayslipStoreTest`, `ApiTest`; `payslips.test.tsx`, `money.test.ts`
Payslip PDF download and access rules	`Api.java`	`PayslipStoreTest`, `ApiTest`
Monthly draft job (`/api/cron/payslips`)	`PayslipService`, `Api.java:663`	`PayslipStoreTest`, `ApiTest` (with a fake PDF renderer)
PDF client	`PdfClient.java`	`PdfClientTest`
Shell, nav, theme, loader	`components/layout`	`shell.test.tsx`, `nav-config.test.ts`
Real PDF from the real `pdf-service` container	`pdf-service/`	**Not tested** by any automated test
nginx proxy, security headers, Docker images, compose	`deploy/`	**Not tested**
Run on the VM behind Traefik	none	**Not tested**
Monthly host cron job	none in repo	**Not tested**
Stress test of the payslip, leave and employee endpoints	`deploy/stress/stress.py` covers sign-in and admins only	**Not tested**
Old-app versus rebuild comparison of every response	none	**Not tested** (Phase 5 of the plan is not done)

No test proves that the whole app works end to end in a browser against the real backend, database and PDF service. Screens were compared with the old app by eye in a browser during development. That is not an automated test and left no file in the repo.

3. Business rules

`old` is `~/lumiether-website/src/lib`. `new` is `backend/src/main/java/app/lumiether`. The rebuild keeps the old rule unless the last column says otherwise. This was compared by reading both files. No automated side-by-side run exists.

Rule	Enforced in new	Enforced in old	Same?
Weekends and the 4 national holidays are not deducted	`domain/Leave.java:58-70`	`leave.ts:61-76`	Yes
Half day counts 0.5, one day only	`Leave.java:64`, `Requests.java:49-51`	`leave.ts:72`, `requests.ts:33-35`	Yes
Sick and casual leave both count; comp-off requests do not draw on the balance	`Leave.java:54`	`leave.ts:59`	Yes
Working a weekend or holiday earns 1 comp-off day (0.5 for half)	`Leave.java:128-132`	`leave.ts:96-100`	Yes
Comp-off expires on the first joining anniversary after the day earned (29 Feb joiners use 28 Feb)	`Leave.java:135-139`, `Dates.java:44`	`leave.ts:103-107`, `dates.ts:70`	Yes
Leave uses the soonest-expiring comp-off first, then the yearly days	`Leave.java:166-200`	`leave.ts:145-176`	Yes
Block a request that takes the balance below zero in any year it touches. The message never gives the shortfall	`Leave.java:283-300`	`leave.ts:299-335`	Yes
Yearly days per category are set by the admin, whole days 0 to 366	`LeaveStore.java:201`, `Api.java:594`, `002_categories_permissions.sql:7`	`store.ts:146`, same migration	Yes
Every category starts at 24 days	`002_categories_permissions.sql:12-14`	same file	Yes. 24 is only the starting value.
Leave: this year to end of next year, at most 90 days, no overlap with live leave	`Requests.java:47-81`	`requests.ts:26-65`	Yes, same messages
Comp-off claim: past day, this year, after joining, a weekend or holiday, no duplicate live claim	`Requests.java:83-100`, index `comp_off_claims_live_key` in `001_init.sql:86`	`requests.ts:67-87`	Yes
Cancel: pending is withdrawn at once; approved and not started becomes a request the admin decides	`Requests.java:109-116`, `LeaveStore.java:130-152`	`requests.ts:96-104`, `store.ts:339-360`	Yes

Rule	Enforced in new	Enforced in old	Same?
Permission: one working day, up to 8 hours, reason up to 200 characters, never deducted	`Requests.java:136-172`, `002_categories_permissions.sql:29-32`	`requests.ts:128-170`	Yes
Employee email must be Gmail; joining date from 2000-01-01	`Employees.java:16,22`	`employees.ts:6,10`	Yes
Last admin cannot be removed; nobody removes themselves	`Store.java:166-177`, `Auth.java:130-132`, trigger `001_init.sql:94-105`	`store.ts:213`, same trigger	Yes
Payslip: basic above 0, deduction from 0 to the basic, month from 2000-01	`Money.java:44-56`, `PayslipService.java:34-47`	`payslip/money.ts:32-47`, `generate.ts:29-33`	Yes
Replacing a published payslip needs a confirm; a draft is replaced without asking	`PayslipService.java:53-55`	`generate.ts:41-43`	Yes
PDF: 30 second limit, output must start with `%PDF`	`PdfClient.java:39,54`	`render.ts:89,96`	Yes
Monthly job: only with `Authorization: Bearer <CRON_SECRET>`, secret 16+ characters, else a bare 404	`PayslipService.java:94-96`, `Api.java:663-665`	`drafts.ts:44-49`	Yes
"Today" is the calendar day in Asia/Kolkata	`Dates.java:12`	`dates.ts:5`	Yes

Where the rebuild differs from the old app

1. **Session cookie.** The new cookie is `lr_session`, signed with `LR_COOKIE_SECRET` (`Sessions.java:15,33`). The old one is `session`, signed with `SESSION_SECRET` (`session.ts:11,21`). Everyone signs in again at cutover. Both are httpOnly and SameSite=Lax.
2. **Origin and JSON check.** The new backend refuses POST, PUT, PATCH and DELETE from an origin not in `ALLOWED_ORIGINS`, and refuses non-JSON bodies (`CsrfGuard.java:57-65`). The old app has no such setting (no `ALLOWED_ORIGINS` anywhere in its `src`).
3. **Three admin screens are now built.** In the old app "Leave requests", "Comp-off" and "Holidays" were `ready: false` (`nav-config.ts:36,37,47`). The rebuild has the first two as lists with approve and reject (`frontend/src/pages/requests.tsx`) and Holidays as a read-only list. Holidays cannot be edited, as before.
4. **Monthly job scheduler.** The old app used Vercel Cron (`vercel.json`: `30 0 1 * *`). The rebuild needs a cron job on the host (section 5).
5. **Dropdowns** use the browser's own list, not the old styled one (decision 15 in `docs/rebuild-plan.md`).
6. **Same quirk kept on purpose.** Past-year leave is an empty map in both apps (`Leave.java:49`, plan item H5).

Where `CLAUDE.md` and the old code disagree, the rebuild follows the code. Examples: admins cannot apply leave for others, and joining dates cannot be edited after adding an employee (plan section 6 and section 8). These are not built.

4. Architecture

```
browser -> Traefik (TLS) -> web (nginx: React files, proxies /api) -> backend (Helidon) -> Postgres
                                                                    \-> pdf (internal network only)
```

- One origin, so no CORS. The web container serves the site and passes `/api` to the backend (`deploy/web/nginx.conf.template`).
- The backend keeps nothing in memory between requests. Rules and messages live on the server. The frontend shows what the server says.
- `pdf` has no published port, no secrets, a read-only filesystem and no outside network (`deploy/docker-compose.yml`).
- Postgres is not in an image. The README says to use an external database. The compose file has an optional `local-db` profile for a throwaway one.
- On start the backend runs `db/migrations` when `RUN_MIGRATIONS` is 1, through `MigrateMain`. It uses the same `schema_migrations` table as the old `scripts/migrate.mjs`, so either tool may run first.
- Passwords use the old scrypt format, so existing hashes still work (`Password.java`, tested against hashes made by the old Node script).

5. Deployment and runbook

Each command says where it runs. Replace `<...>` placeholders.

Warning: this VM is shared

The VM also runs an ERPNext HR system (frappe_docker containers and Traefik) and Portainer. **This app must not change those services.** Do not restart, reconfigure or stop Traefik, Portainer or any frappe or ERPNext container. Do not edit their compose files, volumes, networks or labels. Only add this app's own containers, with their own names and their own compose project. Look at the running containers before every change.

Build (laptop)

```
# laptop: needs Java 21, Maven, Node, Docker
cd ~/lumiether-rebuild
./deploy/build.sh        # backend jar, frontend build, images lumiether-backend and lumiether-web
```

`deploy/build.sh` tags images with the git short sha (plus `-dirty` for uncommitted changes) and `latest`. The VM is arm64, so build the images for arm64 (use `docker buildx` or a build host that is arm64). The `pdf` image is built from `pdf-service/Dockerfile`; compose pins it with `PDF_IMAGE_TAG`.

Test (laptop)

```
# laptop
cd backend && JAVA_HOME=/usr/lib/jvm/java-21-openjdk-amd64 \
  DATABASE_URL_TEST='<throwaway test database URL>' mvn test
cd ../frontend && npm ci && npm test && npm run typecheck && npm run lint
```

`DATABASE_URL_TEST` must never point at the real database. The tests truncate tables and refuse to run if it matches `DATABASE_URL`.

Move images to the VM (laptop, then VM)

```
# laptop
docker save lumiether-backend:<tag> lumiether-web:<tag> lumiether-pdf:<tag> | gzip > lumiether-images.tar.gz
scp lumiether-images.tar.gz <VM_USER>@<VM_HOST>:~/
# VM
gunzip -c ~/lumiether-images.tar.gz | docker load
```

Or push to a registry (not chosen yet, see open items).

Configure (VM)

```
# VM, in this app's own folder, not in the ERPNext folders
cp .env.example .env     # then fill in the values listed below; never commit .env
```

Variable	Meaning
`DATABASE_URL`	Pooled Postgres connection string, `<DATABASE_URL>`
`LR_COOKIE_SECRET`	32+ random characters. Make one with `openssl rand -base64 48`. Not the old `SESSION_SECRET`.
`ALLOWED_ORIGINS`	Public https address only, `<APP_ORIGIN>`. The backend will not start with localhost in it while `COOKIE_SECURE` is true.
`COOKIE_SECURE`	Leave true behind TLS
`ADMIN_EMAIL`, `ADMIN_PASSWORD_HASH`	Bootstrap only, used while the database has no admin. Make the hash with `scripts/hash-password.mjs`.
`CRON_SECRET`	16+ random characters for the monthly job
`POSTGRES_PASSWORD`	Only for the optional local database profile
`IMAGE_TAG`, `PDF_IMAGE_TAG`, `WEB_PORT`	Image tags and the web port

Start, check and stop (VM)

```
# VM, from this app's folder
docker compose -f docker-compose.yml --env-file .env config   # check first; prints errors for missing values
docker compose -f docker-compose.yml --env-file .env up -d
docker compose -f docker-compose.yml --env-file .env ps
curl -fsS http://localhost:<WEB_PORT>/api/health               # expect {"status":"ok"}
docker compose -f docker-compose.yml --env-file .env logs --tail=100 backend
docker compose -f docker-compose.yml --env-file .env down      # stops only this app's containers
```

Do not use `docker system prune` or `docker volume prune` on this VM. They can remove ERPNext data.

Behind Traefik, replace the web service's `ports:` with the commented `labels:` block in the compose file. The entrypoint, network and cert resolver names must be copied from the VM's existing Traefik setup. Only read them. Do not change Traefik. Use a host name that ERPNext does not already use.

Monthly payslip drafts (VM host cron)

The endpoint is `GET /api/cron/payslips`. It makes zero-deduction drafts for last month for everyone with a salary who had joined by then. It never overwrites a payslip. Drafts stay hidden from employees until an admin publishes them.

```
# VM, in the cron table of a normal user; the plan's schedule is 1st of the month at 00:30
30 0 1 * *  curl -fsS -H "Authorization: Bearer $CRON_SECRET" https://<APP_HOST>/api/cron/payslips
```

The VM's time zone is not recorded in the repo. The schedule was written for UTC. `CRON_SECRET` must be available to cron. Do not write its value in the crontab line of a shared file. A wrong secret gives a bare 404. If the PDF service is down the job answers 503 and makes nothing.

Update (laptop, then VM)

Build new images (laptop), load them (VM), change `IMAGE_TAG` in `.env`, then run the `up -d` command again. Migrations run on backend start.

Size and limits (from `deploy/README.md`, measured in the stress test)

Backend memory peaked near 210 MiB. Compose defaults to 1 GB and 2 CPUs. Sign-in is CPU heavy (about 14 per second per core). Failed sign-ins are not rate limited, so add a limit at the proxy if the app is on the open internet. Set memory limits when the container is created, never with `docker update`.

6. Open items

Only items the repo or history shows as open, plus the ones you asked to be listed.

1. **ERPNext hostname.** The repo has only the placeholder `leave.example.com` in the commented Traefik labels. Plan section 9.1 lists the entrypoint, network, cert resolver names and domain as still needed. The repo does not record which host name ERPNext uses. Confirm that the new host name does not clash.
2. **End-to-end testing.** Nothing tests the browser, backend, database and PDF service together. Not tested end to end: every screen against the real backend, the real PDF service, nginx, Traefik, and the employee-side screens next to the old app (only admin screens were compared by eye). Phase 5 of the plan (response comparison with the old app, stress test extended to the new endpoints) is not done.
3. **Monthly cron job and `CRON_SECRET`.** Plan decision 3 says a sample crontab line and a wrapper script go in the README. They are not there yet. The VM time zone is unconfirmed. `CRON_SECRET` has not been set anywhere real.
4. **Uncommitted `client/` deletion.** 31 files under `client/` (the earlier Flutter client) are deleted in the working tree and not committed. They stay uncommitted until the owner says otherwise.
5. **ESLint audit note.** `npm audit` reports one dev-only advisory (GHSA-g3hv-75wg-m249, minimatch, moderate) through ESLint and `typescript-eslint`. It never reaches the built site. `npm audit --omit=dev` reports 0. No version was changed. The decision is waiting (plan sections 5 and 9.3).
6. **Styled select.** The native `<select>` is used (decision 15). Copying the old styled Select into five places is estimated at about a quarter of a day (plan section 9.2). Not decided.
7. **Inter font subset.** The font is the full variable file `frontend/public/fonts/Inter.ttf` (about 860 KB). No subset has been made. The old app used Latin only (`src/app/layout.tsx:9`).
8. **Backups.** Nothing in the repo sets up database backups or a restore test. Postgres is external. Check what the host provides.
9. **Docs are behind the code.** `deploy/README.md` still says there is no web UI, no payslip code and that the PDF service is not called. `docs/rebuild-plan.md` still says everything after Phase 1 is not started. Both need updating.
10. **Registry and image platform.** No registry is chosen. The images the VM needs are arm64.
11. **Payslip layout.** The PDF uses the old app's template. The company address and CIN were marked "to confirm" in commit `02be6f5`. A sample payslip shows a different logo style and number format. Not decided.
12. **Not built, by decision:** admin applies leave for others, holiday editing, joining-date editing (plan section 8, each needs a go-ahead).

7. Decision log

From commit messages and `docs/rebuild-plan.md` section 7.

Decision	Why or where
Follow the code, not `CLAUDE.md`, where they differ	Plan 0 and 6
Keep schema, migrations, WeasyPrint service and cron check unchanged	Plan 0, decisions 5 and 7
Frontend: plain React with Vite and `react-router-dom`	Decision 1
Host: the Oracle VM, Docker, behind the existing Traefik	Decision 2
Monthly job by host cron, not a scheduler in the app	Decision 3
Bouncy Castle for scrypt, tested against hashes from the old Node script	Decision 4

Decision	Why or where
Session in an httpOnly cookie, own secret, everyone signs in again at cutover	Decision 9. The app holds salary data.
`SESSION_SECRET` retired for the rebuild	Decision 19, commit `c0eb581`
Backend refuses to start with localhost origins when `COOKIE_SECURE` is true	Commit `c0eb581`
Tailwind v4 and shadcn parts on Base UI; `cn()` helper from `clsx` and `tailwind-merge`; no `shadcn` package	Decisions 10, 18, 20, 21
`lucide-react` icons and `sonner` toasts	Decision 11
Vitest and Testing Library; layout checked in a real browser	Decision 12
Inter as a self-hosted file	Decision 13
Branch `rebuild/react-helidon`	Decision 14
Native `<select>` for now	Decision 15
Accent colour `#7F22FE`, as the live app renders it	Decision 16
`pdf` service added to compose, internal network only, pinned tag, no ports or secrets	Commit `67948a9`
Postgres password in compose comes from `POSTGRES_PASSWORD`; `local-db` profile kept because the README says to use an external database	Commit `f47324c`
Pending leave is withdrawn at once; approved leave needs the admin to approve the cancellation	Same as the old app; `Requests.java:109-116`
One phase, then stop for review; no push without approval	Plan section 4